

[doc. web n. 10036837]
Provision of May 23, 2024
Register of Provisions
No. 305 of May 23, 2024

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN THE meeting today, attended by
Prof. Pasquale Stanzione, President, Prof.
Ginevra Cerrina Feroni, Vice President, Dr.
Agostino Ghiglia, and Attorney Guido Scorza, members, and
Counsel Fabio Mattei, Secretary General;

HAVING REGARD to Regulation (EU) 2016/679 of the European Parliament
and of the Council, of April 27, 2016, concerning
the protection of natural persons with regard to
the processing of personal data, as well as the free
movement of such data, and repealing Directive
95/46/EC, "General Data Protection Regulation" (hereinafter "Regulation");

HAVING REGARD to Legislative Decree No. 196 of June 30, 2003, containing
"Code regarding the protection of personal data,
containing provisions for the adaptation
of the national legal system to Regulation (EU)
2016/679 of the European Parliament and of the Council, of
April 27, 2016, concerning the protection of
natural persons with regard to the processing of personal data,
as well as the free movement of such data, and repealing Directive 95/46/EC" (hereinafter "Code");

HAVING REGARD to Regulation No. 1/2019 concerning
internal procedures of external relevance,
aimed at carrying out the tasks and
exercising the powers entrusted to the Guarantor for the
protection of personal data, approved by
resolution No. 98 of April 4, 2019, published in
G.U. No. 106 of May 8, 2019, and on www.gpdp.it, doc. web
No. 9107633 (hereinafter "Guarantor Regulation No.
1/2019");

HAVING REGARD to the documentation on file;

HAVING REGARD to the observations made by the Secretary
General pursuant to Article 15 of the Guarantor Regulation No.
1/2000 on the organization and functioning of the
office of the Guarantor for the protection of personal data, on www.gpdp.it, doc.
web No. 1098801;

REPORTING Attorney Guido Scorza;

PREMISE

1. The Complaint

With the complaint submitted on XX, Mr. XX has
reported to this Authority that he exercised the
right referred to in Article 16 of the Regulation against
the Territorial Social Health Company Rhodense located in Garbagnate (Milan), Viale Forlanini
– Tax Code: 09323530965 (hereinafter "Company") and did not
receive a response.

In particular, the complainant stated that: "on

XX, I sent, to the PEC address of the Territorial Social Health Company Rhodense, (...) a request for correction of my personal data (specifically, the physical addresses of registered residence and health domicile), which were incorrectly recorded in the regional health information system, as was clearly evident both from the consultation of the Electronic Health File of the interested party and from the data reported on the electronic prescriptions issued by the primary care physician. More than 150 days after receipt, this request remains unanswered, as the data reported on the electronic prescriptions issued by the general practitioner still appear to be incorrect.”

2. The Investigative Activity

Following this complaint, the Office, with a note dated XX (prot. No. XX), contacted the Company inviting it to comply with the requests of the complainant, and with a note dated XX (prot. No. XX), the latter provided a response to the Office, stating, among other things, that:

- with reference to “the request for correction pursuant to Article 16 of the GDPR, the ASST Rhodense notes that it has already provided, on XX, to correct, in a precise and exhaustive manner, the personal information of the complainant (...), a fulfillment communicated to the complainant on the same date (...), along with the sending of the receipt certifying the requested correction (...);
- “(...) the delay in fulfilling the request in question received from (...) (the complainant) on XX (...) is, in its opinion, solely due to the fact that the latter improperly used the so-called institutional certified email address of the ASST Rhodense (i.e.: protocollo.generale@pec.asst-rhodense), instead of the specific (and convenient) IT platform made available for this purpose, starting from XX, by ASST Rhodense (and conveniently available on the relevant website, at the following link: <https://www.asstrhodense.it/inew/nuovo-sito/home/ambito-territoriale/scelta-revoca.html>) or, in the alternative, instead of the email addresses indicated on the cited link of the company website (i.e.: scelta.revoca.vialavoratori@asst-rhodense.it; scelta.revoca.passirana@asst-rhodense.it; scelta.revoca.settimo@asst-rhodense.it), which, although specifically designated to receive only requests for appointments at the offices of the “choice and revocation” sector, could, nevertheless, have allowed, as usual, a prompt handling of the request, by forwarding it to the relevant parties”;
- “(the) ASST Rhodense highlights that it has fully managed, throughout the year 2022, 7,538 requests for changes to personal data, in addition to the 4,378 received only in the first half of 2023.”

3. Assessments of the Department on the processing carried out and notification of the violation referred to

in Article 166, paragraph 5, of the Code

In relation to what was communicated by the Company, the Office, with an act dated XX (prot. No. XX), initiated, pursuant to Article 166, paragraph 5, of the Code, the procedure for the adoption of the provisions of which pursuant to Article 58, paragraph 2 of the Regulation, against the Company itself, inviting it to submit defensive writings or documents to the Authority, or to request to be heard by the Authority (Article 166, paragraphs 6 and 7 of the Code, as well as Article 18, paragraph 1, Law No. 689 of November 24, 1981). Following what has emerged, the Office has determined that the Company has processed certain personal data of the complainant (residential and health domicile addresses), in violation of the principle of accuracy and has not responded to the request for the exercise of the rights of the data subject, submitted on XX, within the terms of Article 12 of the Regulation. This constitutes a violation of Article 5, paragraph 1, letter d) of the Regulation, as well as Article 12, in relation to Article 16 of the same Regulation.

Regarding this last aspect of the violation, the Company provided a response to the complainant on XX, specifically following the submission of the complaint to the Authority by the data subject (XX) and prior to the receipt of the aforementioned invitation to comply with the complainant's requests, sent by the Authority itself.

By certified email (PEC) on XX, the Company submitted its defensive memoranda, in which, in particular, reiterating what was already stated in the aforementioned response provided on XX, it also declared, among other things, that:

- "the delay in fulfilling the request for rectification under Article 16 of the GDPR made by the complainant (...) is, in its opinion, solely attributable to the fact that the latter improperly used the so-called institutional email address of ASST RHODENSE (i.e.: protocollo.generale@pec.asst-rhodense.it), (in addition to the channels indicated in the aforementioned response note of XX, also) instead of the appropriate form designated for exercising the rights referred to in Chapter III) of the GDPR, readily made available by ASST RHODENSE in the "Privacy" section of its website (link: <https://www.asst-rhodense.it/nuovo-sito/home/PRIVACY/documenti/policyProcedure/Modulo%20esercizio%20diritti.pdf>), which should then be sent to the email address of the Company's Privacy Office (i.e.: privacy@asst-rhodense.it) or to that of the appointed Data Protection Officer (i.e.: responsabileprotezionedati@asst-rhodense.it)";
- "ASST RHODENSE therefore believes that it has adopted (and then made readily available, for the benefit of every interested party) a series of organizational measures (namely: dedicated platform; as many as 5 email addresses (or: scelta.revoca.vialavoratori@asst-rhodense.it; scelta.revoca.passirana@asst-rhodense.it; scelta.revoca.settimo@asst-rhodense.it; privacy@asst-rhodense.it; responsabileprotezionedati@asst-rhodense.it; dedicated form) that are adequate, reasonable, and easy to use and find within the company's website, in order to allow every interested party to exercise any right regulated in Chapter III) of the GDPR".
- "Having read the observations made by the Privacy Authority specifically regarding point 53) of the EDPB Guidelines No. 1/2002 (...) ASST RHODENSE notes, however, that, in the subsequent point 54) of the same Guidelines, the EDPB provided a specific exemption in favor of the Data Controller, in the event that they receive, as in the present case, a request to exercise a right under Chapter III) of the GDPR to an email address clearly not intended to receive such requests (official English version: "It should be noted that the controller is not obliged to act on a request sent to a random or incorrect email (or postal) address, not directly provided by the controller, or to any communication channel that is clearly not intended to receive requests regarding data subject's rights, if the controller has provided an appropriate communication channel, that can be used by the data subject"; unofficial Italian translation: "Si precisa che il titolare del trattamento non è obbligato a dare seguito ad una richiesta inviata in modo casuale o errata indirizzo email (o postale), non fornito direttamente dal titolare, né a qualsiasi canale di comunicazione che chiaramente non è destinato a ricevere richieste relative ai diritti dell'interessato, qualora il titolare del trattamento ne abbia fornito un canale di comunicazione appropriato, che può essere utilizzato dall'interessato").

4. Outcome of the Investigative Activity

Taking note of what has been represented by the Company in the documentation on file and in the defensive memoranda, highlighting that the processing of personal data must occur in compliance with the applicable regulations on personal data protection and, in particular, the provisions of the Regulation and the Code, the following observations are made.

4.1 Failure to Respond to the Request for the Exercise of Rights (Article 12 in relation to Article 16 of the Regulation)

Regarding information, communications, and transparent methods for the exercise of the rights of the data subject, Article 12, paragraph 3, of the Regulation establishes that the data controller must respond to the request of the data subject, made pursuant to Articles 15 to 22 of the Regulation, without undue delay and, in any case, no later than one month from the receipt of the same. This term may be extended by two months, if necessary, taking into account the complexity and number of requests, provided that the data subject is informed of such extension and the reasons for the delay within one month of receiving the request. If the data controller does not comply with the request of the data subject, they must, in any case, inform the data subject without delay and, at the latest, within one month from the receipt of the request, of the reasons for non-compliance and the possibility to lodge a complaint with a supervisory authority and to seek judicial remedy (recital 59 and Article 12, paragraph 4, of the Regulation).

In the document "Guidelines 01/2022 on data subject rights - Right of access, Version 2.0 adopted on 28 March 2023," the European Committee provides guidance to data controllers regarding the exercise of the right of access to data as per Article 15 of the Regulation, identifying methods and forms for submitting requests (see, with reference to the matter in question, in particular, the Executive Summary at the beginning of the document, as well as paragraph 3.1.2 "Form of the request," points 52 to 56).

The controller, in the response sent to the Authority following the invitation to comply with the requests made by the data subject formulated by the Office, as well as in the defense memorandum, justified the lack of response to the data subject's request, in the terms of Article 12 of the Regulation, based on the fact that the data subject "improperly used the certified email address known as the institutional one of Asst Rhodense (i.e., protocollo.generale@pec.asst-rhodense)" without utilizing other communication channels designated for that purpose.

To this end, in the defense memorandum submitted on XX, the controller, in support of this argument, also asserted that what is indicated in point 54 of paragraph 3.1.2 "Form of the request" of the aforementioned Guidelines would constitute an exemption for the data controller, stating that "(...) the data controller is not obliged to respond to a request sent to a random or incorrect email (or postal) address not directly provided by the controller, nor to any communication channel that is clearly not intended to receive requests related to the rights of the data subject, provided that the data controller has provided an appropriate communication channel that can be used by the data subject" - (Unofficial translation).

In this regard, it should be noted that, as indicated by the cited Guidelines, a "random or incorrect" address does not refer to any other address that is not the one designated for receiving requests for the exercise of rights under Articles 15 to 22 of the Regulation. The European Data Protection Committee does not exclude, in fact, that once the controller has indicated this last address/channel as the preferred one for receiving such requests, other potential institutional addresses of the same controller may constitute a valid channel - for the purpose of the existence of the obligation for the controller to manage the request - from which to "redirect" the request to the competent Office.

This can be inferred both from a systematic reading of what is generally expressed in paragraph 3.1.2 "Form of the request," points 52 to 56, of the aforementioned Guidelines, and specifically, with reference to certain sentences of those points.

In particular, for this purpose, reference is made not only to the sentence in point 53 - already cited by

this Authority in the initiation of the procedure pursuant to Article 166 of the Code: “(...) if the data subject makes a request using a communication channel provided by the controller, which is different from the one indicated as the preferable one, such request shall be, in general, considered effective and the controller should handle such a request accordingly (...)” - and the related explanatory note on what is to be understood as a valid communication channel/electronic address even if not indicated as preferable (see note no. 28 related to a sentence of point no. 53: “this may include, for example, communication data of the controller provided in its communications addressed directly to data subjects or contact data provided by the controller publicly, such as in the controller's privacy policy or other mandatory legal notices of the controller (e.g., owner or business contact information on a website)” - (Unofficial translation)), but also to what is highlighted in example no. 8, following point no. 56, as well as in the introductory part of the cited Guidelines, titled “Executive Summary.”

In this latter section, in fact, and specifically in the paragraph “General considerations on the assessment of the data subject’s request,” the European Committee asserts that: “(...) the data subject is not required to use these specific channels and may instead send the request to an official contact point of the controller” - (Unofficial translation); in such a case “(...) the controller should make all reasonable efforts to make its services aware of the request, which was made through the general email, so that it can be redirected to the data protection contact point and answered within the time limits provided for by the GDPR. Moreover, the controller is not entitled to extend the period for responding to a request, merely because the data subject has sent a request to the controller’s general e-mail address, not the controller's data protection contact point e-mail address” (“(...) the data controller must make every reasonable effort to inform its services of the request submitted via the general email, so that it can redirect it to the data protection contact point and respond within the deadlines set by the GDPR. Furthermore, the data controller does not have the right to extend the deadline for responding to a request, merely because the data subject has sent a request to the data controller's general email address and not to the data protection contact point email address of the data controller” – unofficial translation) (see example no. 8, p. 23 of the cited Guidelines).

In light of the above, it is believed that the institutional certified email address of the Company, protocollo.generale@pec.asst-rhodense, used by the data subject to send the request in question, on date XX, although not coinciding with the one indicated by the Company for the submission of requests to exercise rights, cannot be considered a “random or incorrect” address in the sense understood by the European Committee in the aforementioned Guidelines, but rather constitutes an address through which “the data controller must make every reasonable effort to inform its services of the request submitted via the general email, so that it can redirect it to the data protection contact point and respond within the deadlines set by the GDPR. Furthermore, the data controller does not have the right to extend the deadline for responding to a request, merely because the data subject has sent a request to the data controller's general email address (...)” (see example no. 8, p. 23 of the aforementioned Guidelines, cited above).

Therefore, it appears that the health authority did not provide a response, within the deadlines set by Article 12 of the Regulation, to the request for rectification of personal data pursuant to Article 16 of the same Regulation, made by the data subject on date XX. Specifically, the Company provided a response on date XX, that is, after 156 days from the date of the data subject's request, specifically following the filing of the complaint by the latter to the Guarantor (XX) and prior to the receipt of the aforementioned invitation from the Authority to comply with the complainant's requests (note of XX - prot. no. XX).

4.2 Compliance with applicable processing principles and, in particular, the principle of accuracy (Article 5, paragraph 1, letter d) of the Regulation)

The controller must process data in such a way that they are “accurate and, where necessary, kept up to date; all reasonable measures must be taken to erase or rectify inaccurate data without delay, in relation to the purposes for which they were processed (“accuracy”)” (Article 5, paragraph 1, letter d) of the Regulation).

In light of the lack of response to the request made by the data subject for the amendment of their personal data due to the update of the street naming adopted ex officio by the Municipality of residence (XX), the Company, considering that the data subject had attached the certificate of demographic variation adopted by that Municipality to their request, should have updated the data in compliance with the principle of “accuracy” of the data referred to in Article 5, paragraph 1, letter d), of the Regulation.

The Company rectified the inaccurate data on date XX, following the filing of the complaint to the Guarantor (XX) by the data subject and prior to the receipt of the aforementioned invitation from the Authority to comply with the complainant's requests (note of XX - prot. no. XX).

5. Conclusions.

In light of the evaluations mentioned above, taking into account the statements made by the data controller during the investigation and considering that, unless the act constitutes a more serious crime, anyone who, in a proceeding before the Guarantor, falsely declares or certifies news or circumstances or produces false acts or documents is liable pursuant to Article 168 of the Code “Falsehood in declarations to the Guarantor and interruption of the execution of the tasks or exercise of the powers of the Guarantor”, the elements provided by the data controller in the aforementioned defensive memorandum, although deserving of consideration, do not allow for overcoming the observations notified by the Office with the aforementioned initiation act of the procedure, nor do any of the cases provided for in Article 11 of the Guarantor's regulation no. 1/2019 apply.

Therefore, all that has been stated, based on the current state of acts and statements provided, in relation to the matter in question, it is established that the Company, as the data controller:

- has processed certain personal data of the complainant (residential and health domicile addresses), in violation of the accuracy principle, in breach of Article 5, paragraph 1, letter d) of the Regulation;
- has not responded to the request for the exercise of the rights of the data subject made on date XX within the deadlines set by Article 12 of the Regulation; this, in violation of Article 12, in relation to Article 16 of the same Regulation.

In this context, considering that the conduct of the controller has exhausted its effects as the Company provided a response, after 156 days from the date of the data subject's request, rectifying the inaccurate data, the conditions for the adoption of measures, of a prescriptive or prohibitory nature, pursuant to Article 58, paragraph 2, of the Regulation do not exist.

6. Adoption of the injunction order for the application of the administrative pecuniary sanction and accessory sanctions (arts. 58, par. 2, lett. i and 83 of the Regulation; art. 166, par. 7, of the Code). The violation of arts. 5, par. 1, lett. d), and 12, in relation to art. 16 of the Regulation, caused by the conduct carried out by the Company, is subject to the application of the administrative pecuniary sanction pursuant to art. 83, par. 5, lett. a) and b) of the Regulation and art. 166, par. 2, of the Code. The Guarantor, pursuant to arts. 58, par. 2, lett. i) and 83 of the Regulation, as well as art. 166 of the Code, has the power to “impose an administrative pecuniary sanction pursuant to article 83, in addition to the [other] [corrective] measures referred to in this paragraph, or in lieu of such measures, depending on the circumstances of each individual case” and, in this context, “the Board [of the Guarantor] adopts the injunction order, which also provides for the application of the accessory administrative sanction of its publication, in whole or in part, on the Guarantor's website pursuant to article 166, par. 7, of the Code” (art. 16, par. 1, of the Guarantor's Regulation no. 1/2019).

In this case, in relation to the conduct carried out by the data controller, considering that it involved related processing, it is deemed necessary to apply paragraph 3 of art. 83 of the Regulation, which provides that “If, in relation to the same processing or related processing, a data controller [...] violates, with intent or negligence, various provisions of this regulation, the total amount of the administrative pecuniary sanction does not exceed the amount specified for the most serious violation, the total amount of the sanction is calculated so as not to exceed the maximum penalty provided for by the same art. 83, par. 5” (see also the document of the European Data Protection Board “Guidelines 04/2022 on the calculation of administrative fines under the GDPR” Version 2.1 adopted on May 24,

2023). Consequently, the total amount of the sanction is to be quantified up to 20,000,000 euros (maximum so-called “static” penalty).

The aforementioned administrative pecuniary sanction imposed, depending on the circumstances of each individual case, must be determined in amount taking into account the principles of effectiveness, proportionality, and deterrence, as indicated in art. 83, par. 1, of the Regulation.

Regarding the assessment of the severity of the violation (art. 83, par. 2, lett. a), b) and g) of the Regulation), it is believed that the level of severity is to be considered low, as it was an isolated case and in the absence of intent, and it is taken into account that the finding sent on XX – that is, after 156 days from the date of receipt of the request by the Company – was carried out immediately following the filing of the complaint with the Guarantor by the interested party (XX) and prior to the invitation to comply with the requests of the complainant made by the Authority (note of XX - prot. no. XX).

In relation to the assessment of the additional elements provided for by art. 83, par. 2 of the Regulation, such as aggravating and mitigating circumstances, it is noted that:

- no prior measures concerning relevant violations have been adopted against the Company (art. 83, par. 2, lett. e) of the Regulation);
- the Company has demonstrated a high degree of cooperation with the Authority at all stages of the procedure (art. 83, par. 2, lett. f) of the Regulation);
- the Authority became aware of the case in question following a complaint filed by the interested party (art. 83, par. 2, lett. h) of the Regulation);
- the data controller specified that it had to manage “(...) in the entire year 2022, no. 7538 requests for changes to personal data, to which are added the no. 4378 received, only, in the first half of 2023” (art. 83, par. 2, lett. k) of the Regulation).

In light of the aforementioned elements, assessed as a whole, it is deemed appropriate to determine the amount of the pecuniary sanction provided for by art. 83, par. 5 of the Regulation, in the amount of 4,500.00 euros (four thousand five hundred) for the violation of arts. 5, par. 1, lett. d) and 12 in relation to art. 16 of the Regulation as an administrative pecuniary sanction deemed, pursuant to art. 83, par. 1, of the Regulation, effective, proportionate, and deterrent.

It is also deemed that the accessory sanction of publication on the Guarantor's website of this provision, as provided for by art. 166, par. 7 of the Code and art. 16 of the Guarantor's Regulation no. 1/2019, should be applied considering that the violation concerns the rights of the interested parties. Finally, it is noted that the conditions referred to in art. 17 of Regulation no. 1/2019 concerning internal procedures with external relevance, aimed at carrying out the tasks and exercising the powers entrusted to the Guarantor, are met.

ALL OF THE ABOVE, THE GUARANTOR

declares the unlawfulness of the processing of personal data carried out by the Territorial Social Health Company Rhodense located in Garbagnate, Viale Forlanini – C.F.: 09323530965, for the violation of arts. 5, par. 1, lett. d) and 12 in relation to art. 16 of the Regulation as stated in the reasoning;

ORDERS

the aforementioned Company to pay the sum of 4,500.00 euros (four thousand five hundred/00) as an administrative pecuniary sanction, pursuant to the

Articles 58, paragraph 2, letter i) and 83 of the Regulation, as well as Article 166 of the Code, for the violations indicated in this provision, according to the methods highlighted in the annex, within 30 days from the notification of the reasoning; it is represented that the offender, pursuant to Article 166, paragraph 8, of the Code, has the option to settle the dispute by paying, within the 30-day period, an amount equal to half of the imposed sanction.

****ORDERS****

the aforementioned Health Authority, in the event of failure to settle the dispute pursuant to Article 166, paragraph 8, of the Code, to pay the sum of €4,500.00 (four thousand five hundred) according to the methods indicated in the annex, within 30 days from the notification of this provision, under penalty of the adoption of the consequent executive acts in accordance with Article 27 of Law No. 689/1981.

****DECIDES****

the full publication of this provision on the website of the Guarantor pursuant to Article 166, paragraph 7, of the Code, and considers that the conditions referred to in Article 17 of Regulation No. 1/2019 concerning internal procedures of external relevance, aimed at carrying out the tasks and exercising the powers delegated to the Guarantor, which provides for the annotation in the internal register of the Authority, are met.

Against this provision, it is possible to file an appeal before the ordinary judicial authority, under penalty of inadmissibility, within thirty days from the date of communication of the provision itself or within sixty days if the appellant resides abroad (Article 78 of the Regulation, Articles 152 of the Code and 10 of Legislative Decree No. 150/2011).

Rome, May 23, 2024

THE PRESIDENT

Stanzione

THE REPORTER

Scorza

THE SECRETARY GENERAL

Mattei